Capacity-Indexed Decay of Exploit-Likelihood Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Paper 5 reported that EPSS-only vulnerability prioritization decays from mean Precision@50 of 0.331 at maintenance Window 1 to 0.034 at Window 6 on the synthetic EEHDA fleet at a single capacity-arrival operating point ($K = 50$ pairs/window, $\lambda = 3$ new CVEs/window). This paper sweeps the two-dimensional grid $K \in \{10, 25, 50, 100, 200\}$ and $\lambda \in \{1, 3, 6, 12\}$ over six bi-weekly windows on the 25 evaluation seeds inherited from Paper 5, producing 15,000 pre-registered result rows.

Three pre-registered findings are reported honestly. First, EPSS-only exhibits a negative decay slope in all 20 cells (mean slope range -0.025 to -0.052 P@50/window); no (K, λ) combination in the grid produces steady-state EPSS performance, so the pre-registered ratio hypothesis (H3) reduces to a descriptive bound. Second, the predicted monotone scaling of EPSS decay with K at fixed λ (H1) and with λ at fixed K (H2) is rejected: Spearman correlations fall well below the pre-registered $|\rho| \geq 0.8$ threshold across most slices, indicating that the underlying composition dynamics are non-monotone in the synthetic regime studied. Third, and most importantly, the pre-registered claim that HygienePrio-full retains W6 P@50 ≥ 0.40 across all cells (H4) is rejected. At $K \in \{100, 200\}$ HygienePrio-full collapses alongside EPSS-only, falling to 0.062 at the most aggressive cell ($K = 200, \lambda = 1$). The mechanism is symmetric to EPSS decay: high-throughput remediation exhausts the high-HRS tail of the fleet, after which HygienePrio's host-level signal becomes near-uninformative.

The robustness claim that survives is per-pair: HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of all (cell, seed, window) triples (2,881/3,000), with per-cell dominance never below 76.7%. The operational implication, in contrast to Paper 5's single-cell conclusion, is that hygiene-augmented scoring is a strict improvement over EPSS-only across all capacity regimes studied, but the absolute P@50 floor it provides degrades at high capacity in the same way exploit-likelihood scoring does. All claims are bounded to the synthetic evaluation context; external validation on real fleet telemetry with longitudinal exploitation outcome data is required before any deployment recommendation, and is itself a stronger requirement than Paper 5 implied.

Index Terms—vulnerability prioritization; EPSS; remediation capacity; CVE arrival rate; multi-window scheduling; sensitivity sweep; reproducibility.

I. Introduction

Single-cell evaluations of vulnerability prioritization methods report performance at one operating point: one remediation capacity, one CVE arrival rate, one window cadence. Paper 5 [1] extended single-window evaluation [2] to six rolling windows at a fixed cell ($K = 50, \lambda = 3$) and showed that EPSS-only Precision@50 decays from 0.331 to 0.034 as the high-EPSS tail of the backlog is exhausted by capacity-constrained remediation. That study left two operational questions unresolved:

Q1. How does decay depend on capacity K? Faster remediation should drain the high-EPSS tail faster — but does the relationship scale monotonically?

Q2. How does new-CVE arrival rate λ replenish the high-EPSS tail? Above some critical λ, decay should slow or stall.

Both matter operationally: an organisation with $K = 200, \lambda = 12$ sits in a very different regime from one with $K = 25, \lambda = 1$, and Paper 5's single-cell result cannot tell either organisation what to expect.

This paper sweeps a pre-registered 5×4 grid of (K, λ) on the 25 evaluation seeds inherited from Paper 5, generating 15,000 result rows under the same EEHDA fleet model. We report three findings honestly against the pre-registration.

A. Contributions

- C1 — Two-dimensional capacity-arrival sweep. A pre-registered grid of 20 (K, λ) cells on the EEHDA fleet, extending Paper 5's single-cell simulator with explicit cell-level control of capacity and Poisson arrival rate; 15,000 frozen result rows.
- C2 — Universal EPSS decay across the grid. EPSS-only decay slope is strictly negative in all 20 cells (range -0.025 to -0.052 P@50/window). The pre-registered ratio hypothesis H3 fails to identify a steady-state cell within the grid; we report this descriptively rather than as a binary claim.
- C3 — Predicted monotonicity rejected. Spearman correlations for the predicted monotone scaling of EPSS decay with K (H1) and λ (H2) fall below the pre-registered $|\rho| \geq 0.8$ threshold across most slices. The underlying compositional dynamics are non-monotone in the synthetic regime studied; we report the non-monotonicities directly rather than smoothing them.
- C4 — HygienePrio also collapses at high capacity. The pre-registered claim that HygienePrio-full retains W6 P@50 ≥ 0.40 across all cells (H4) is rejected. At $K = 200$, HygienePrio-full falls to a W6 mean of 0.062 ($\lambda = 1$). The mechanism is symmetric to EPSS-only's collapse: high-throughput remediation exhausts the high-HRS tail, after which the hygiene signal carries little additional information.
- C5 — Per-pair dominance survives. HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of all (cell, seed, window) triples (2,881/3,000). Minimum per-cell dominance is 76.7%. Hygiene augmentation is a

strict improvement over EPSS-only in the regimes studied, but is not a guarantee of absolute scheduling quality at the high-capacity end.

B. Relationship to Prior Papers

This paper is the sixth in the VulnPrio research sequence. Paper 1 [3] reported a null result for CVE-level augmentation at one window. Paper 3 [4] demonstrated discriminative structure in hygiene signals. Paper 4 [2] integrated those signals into the HygienePrio scorer and showed ≈ 31 pp Precision@50 improvement over EPSS-only at one window. Paper 5 [1] showed the gap is robust across six windows at one cell. The present paper sweeps the cell-defining parameters and finds that the absolute P@50 of both methods is regime-dependent, with HygienePrio's absolute floor failing at high capacity — while its relative advantage over EPSS-only is preserved across the grid.

II. Background

A. Capacity-Constrained Patch Scheduling

Enterprise vulnerability remediation operates under a hard capacity constraint: a finite team can patch a finite number of (host, CVE) pairs per maintenance window. CISA Binding Operational Directive 22-01 [5] mandates 15-day remediation of Known Exploited Vulnerabilities for federal agencies; NIST SP 800-40 Rev. 4 [6] recommends risk-based patch management with documented capacity allocation. In practice the capacity K —the number of (host, CVE) pairs remediated per window— is bounded by patching personnel, change-window length, and rollback risk budgets, and varies by an order of magnitude across organisations.

B. CVE Arrival as Backlog Replenishment

New CVEs are disclosed continuously: the National Vulnerability Database publishes new entries daily, and individual organisations see their backlog grow as scanners surface previously unindexed exposures. The arrival rate of new actionable CVEs per maintenance window —denoted λ in this paper— depends on fleet size, scanner coverage, and the upstream CVE disclosure rate. The 2026 DBIR [7] reports vulnerability exploitation as the leading initial-access vector, underscoring the operational importance of the rate at which actionable disclosures accumulate.

C. The Capacity-Versus-Arrival Race

The interaction (K, λ) defines a regime: when K greatly exceeds λ, the backlog is drained faster than it is replenished, and the high-EPSS tail of the residual backlog shrinks over time. When λ matches or exceeds K, the backlog is in steady state and the EPSS distribution of unpatched pairs remains approximately stationary. Paper 5 [1] demonstrated EPSS-only decay in the single regime ($K = 50, \lambda = 3$) but did not characterise the boundary between drain and steady state. This paper sweeps both axes to map that boundary.

D. EPSS Score Dynamics

EPSS scores [8] are a per-CVE rolling 30-day exploit probability. Ravalico et al. [9] characterised per-CVE EPSS drift; their study is complementary to ours — they measure the per-CVE score random walk; we measure how prioritisation effectiveness degrades through compositional change of the residual backlog. The two effects are independent: the compositional collapse documented here would occur even with perfectly stable per-CVE EPSS values.

III. Problem Formulation

A. Sweep Setting

We extend Paper 5's [1] single-cell multi-window simulation to a two-dimensional sweep over remediation capacity K and Poisson arrival rate λ. Let F_w denote the fleet state at window $w \in \{1, \ldots, W\}$ with $W = 6$. For each cell (K, λ) in the grid, each window executes:

1) Score. Compute $S_w(h, c)$ for all unpatched applicable pairs $(h, c) \in V_w$ using F_w.
2) Select. Rank pairs descending; the top-K action set A_w is selected by HygienePrio-full (used as the policy that drives fleet evolution for all methods scored at this window).
3) Remediate. Mark pairs in A_w patched; reduce host patch debt and recover telemetry freshness for acted hosts.
4) Disclose. Draw $n \sim \text{Poisson}(\lambda)$ new (host, CVE) rows with EPSS, CVSS, and KEV attributes sampled from the Paper 4 [2] fixture distributions.
5) Update. Random-walk perturb EPSS scores ($\sigma = 0.02$); accumulate telemetry staleness for non-acted hosts.
6) Advance. $F_{w+1} \leftarrow$ updated state.

B. Ground Truth (per Window)

Identical to Paper 5 [1]: (h, c) is a positive at window w if $\text{EPSS}(c) > 0.10$, $\text{HRS}(h)$ exceeds the fleet's 75th percentile at w, and $(h, c) \in V_w$. The HRS-percentile threshold is recomputed per window; this is a structural choice inherited from Paper 5 and is restated as a threat in §IX.

C. Metrics

- P@K' (primary), with $K' \in \{50, 100, 250\}$ metric levels reported per cell, per window, per seed. Note that K' is the metric-evaluation level, separate from the cell's capacity K that controls fleet evolution.
- Decay slope. OLS slope of P@50 versus window index ($w = 1, \ldots, 6$), per (cell, seed, method).
- W6 retention. Cell-mean P@50 at $w = 6$ per method.

D. Pre-Registered Hypotheses

H1 EPSS-only mean decay slope is monotonically more negative as K increases at every fixed λ (Spearman $\rho \leq -0.8$).

TABLE I
Sweep grid (locked before evaluation).

Axis	Values
Capacity K	$\{10, 25, 50, 100, 200\}$
Arrival rate λ	$\{1, 3, 6, 12\}$
Windows W	6
Methods	HP-full, EPSS, HRS, CVSS, Rand
Seeds	25 (105–129)
Total cells	20
Total rows	15,000

H2 EPSS-only decay slope is monotonically less negative (closer to zero) as λ increases at every fixed K (Spearman $\rho \geq +0.8$).

H3 A critical ratio K/λ exists at which the EPSS-only slope ≥ -0.01 P@50/window (descriptive; no binary test).

H4 HygienePrio-full retains W6 mean P@50 ≥ 0.40 across all 20 cells.

The full pre-registration protocol, including hypotheses, decision rules, and stop rules, is archived at paper6/design/PAPER6_PROTOCOL.md and accompanies the artifact release.

IV. Dataset and Sweep Grid

A. Synthetic Fleet

All evaluations use the EEHDA synthetic fleet generator from Paper 4 [2], identical in structural priors to Papers 4 and 5: 1,000 users, 830 hosts, ∼3,500 (host, CVE) pairs at window 1, drawn from DBIR-calibrated patch lag and NVD-calibrated CVSS distributions with ∼12% of CVEs at EPSS > 0.10 and ∼8% KEV prevalence. New CVE disclosures at $w > 1$ are drawn from the same fixture distributions.

B. Sweep Grid

The grid spans 20 cells. Cells differ only in (K, λ); all other simulation parameters (patch debt reduction $\Delta_{\text{patch}} = 0.15$, EPSS random-walk $\sigma = 0.02$, telemetry drift +0.08/window, recovery −0.30, KEV prevalence 0.08, calibrated HRS and scorer weights) inherit from Paper 5's pre-registration verbatim.

C. Seed Protocol

The 25 evaluation seeds (105–129) are identical to Paper 5's evaluation set, enabling per-seed paired comparisons across cells. The five calibration seeds (100–104) are not used in this study because no weight re-fitting is performed — the Paper 4 calibrated weights are used at every cell.

V. Methodology

A. Scorers

All five scorers are inherited verbatim from Paper 4 [2] and Paper 5 [1] with fixed calibrated weights:

$$\begin{aligned} S_{\text{HP}}(h, c) = 0.7\,\text{EPSS}(c) &+ 0.5\,\text{HRS}(h) \\ &+ 0.1\,\text{KEV\_recency}(c) \\ &+ 0.2\,\big(\text{EPSS}(c) \cdot \text{HRS}(h)\big), \end{aligned} \tag{1}$$

$$\begin{aligned} \text{HRS}(h) = 0.50\,&\text{PatchPosture}(h) \\ &+ 0.30\,\text{ADExposure}(h) \\ &+ 0.20\,\text{TelFresh}(h). \end{aligned} \tag{2}$$

Baselines are EPSS-only ($S = \text{EPSS}(c)$), HRS-only ($S = \text{HRS}(h)$), CVSS-only ($S = \text{CVSS}_{\text{base}}(c)$ [10]), and Random (seed-deterministic uniform ranking).

B. Fleet-State Evolution

The window-w fleet F_w is advanced to F_{w+1} in four steps:

1) Remediate. The top-K pairs selected by HygienePrio-full are marked patched. PatchPosture is recomputed.
2) Disclose. Draw $n_w \sim \text{Poisson}(\lambda)$ new (host, CVE) rows. Each row is attached to a random host drawn uniformly from the fleet, with EPSS, CVSS, and KEV attributes sampled from the Paper 4 [2] fixture distributions.
3) EPSS update. Apply $\mathcal{N}(0, 0.02^2)$ random-walk perturbation to EPSS scores of all surviving unpatched pairs; clip to $[10^{-4}, 1]$.
4) Telemetry update. For acted hosts, decrement staleness days by 9.0 (recovery −0.30). For non-acted hosts, increment by 2.4 (drift +0.08), capped at 60 days.

RNG seeds are derived from (seed, window_index) so each window is independently reproducible.

C. Selection Policy

HygienePrio-full's top-K pairs drive fleet evolution at every window of every cell, for every method evaluated at that window. Each method is scored on the same evolving backlog; comparisons are therefore conditional on the HygienePrio-driven trajectory. This avoids the non-identifiability problem in which an EPSS-only-driven fleet and a HygienePrio-driven fleet would evolve to different residual backlogs, making subsequent method comparisons un-attributable. The choice and its consequence are documented as an internal-validity threat in §IX.

D. Decay Slope

For each (cell, seed, method), we fit an ordinary least-squares line to the six per-window P@50 values (w, p_w), $w = 1, \ldots, 6$, and record the slope $\hat{\beta}$. Negative slope indicates degrading precision; $|\hat{\beta}|$ measures decay rate in units of P@50 per window. Cell-level slope is reported as the mean of per-seed slopes with a 95% percentile bootstrap CI (10,000 resamples).

E. Hypothesis Tests

H1 and H2. For EPSS-only, we report Spearman ρ between slope and K at each fixed λ (H1) and between slope and λ at each fixed K (H2) [11]. The pre-registered threshold for "monotone" is $|\rho| \geq 0.8$.

H3. We compute the maximum K/λ ratio at which the cell slope satisfies $\hat{\beta} \geq -0.01$ and report it descriptively as the steady-state boundary.

H4. We report W6 mean P@50 for HygienePrio-full at every cell and check that all 20 cells satisfy mean ≥ 0.40.

VI. Experimental Setup

A. Pre-Registration

The protocol — including research questions, (K, λ) grid, hypotheses, statistical decision rules, and stop rules — was fixed before any sweep result was inspected. The full protocol is archived as paper6/design/PAPER6_PROTOCOL.md and accompanies the artifact release.

B. Calibration Procedure

No calibration is performed in this study. Scorer weights $(\alpha, \beta, \gamma, \delta) = (0.7, 0.5, 0.1, 0.2)$ and HRS weights $(0.5, 0.3, 0.2)$ are inherited verbatim from Paper 4 [2]. This is intentional: the question is how a fixed HygienePrio configuration behaves across operating regimes, not whether per-cell re-fitting could rescue it. Paper 5's H3 ablation already established that per-window recalibration improves P@50 by up to +21 pp at fixed (K, λ); the present sweep isolates the regime-sensitivity question.

C. Sweep Execution

For each (cell, seed, window):

1) Generate the Window-1 EEHDA fleet from the seed; this is identical across cells because the cell-defining parameters affect only the evolution, not the initial state.
2) Score all unpatched applicable pairs with each of the five methods.
3) Compute P@50, P@100, P@250 from the per-window ground-truth labels (§III).
4) Persist one row per (cell, seed, window, method) to sweep_results.csv.
5) Advance the fleet using HygienePrio-full's top-K pairs and a Poisson(λ) new-CVE disclosure draw.

Total: 5 capacity levels $\times$ 4 arrival rates $\times$ 25 seeds $\times$ 6 windows $\times$ 5 methods = 15,000 rows.

D. Statistical Reporting

Cell-level point estimates are means across the 25 evaluation seeds. 95% confidence intervals are percentile bootstrap with 10,000 resamples [12]. Decay slopes are OLS-fit per (cell, seed, method) and then aggregated as the per-seed mean with a 95% percentile bootstrap CI. Spearman correlations for H1 and H2 are computed on cell-mean slopes (5 points per slice for H1, 4 points per slice for H2) [11].

No null-hypothesis significance tests are reported; comparisons rely on CI overlap and the pre-registered Spearman thresholds.

TABLE II
Mean P@50 decay slope (per window) for EPSS-only (top) and HygienePrio-full (bottom). Negative = decay; near zero = steady.

	Capacity K				
λ	10	25	50	100	200
EPSS-only					
1	-0.038	-0.047	-0.051	-0.043	-0.035
3	-0.039	-0.048	-0.052	-0.044	-0.032
6	-0.035	-0.046	-0.051	-0.042	-0.030
12	-0.036	-0.047	-0.051	-0.043	-0.025
HygienePrio-full					
1	-0.010	+0.001	-0.019	-0.055	-0.113
3	-0.009	-0.001	-0.017	-0.058	-0.109
6	-0.006	-0.001	-0.019	-0.054	-0.105
12	-0.012	+0.000	-0.012	-0.055	-0.098

E. Reproducibility

The sweep driver, analysis script, and figure generator are released under the MIT licence with the artifact. From paper6/:

```
PYTHONPATH=src python3 src/run_sweep.py
PYTHONPATH=src python3 src/analyze_sweep.py
PYTHONPATH=src python3 src/make_figures.py
```

The driver re-uses Paper 5's window_sim and Paper 4's hygieneprio packages via sys.path injection (no code copy). Determinism is inherited from Paper 5's per-(seed, window, step) RNG seeding.

VII. Results

All numerical claims in this section trace to paper6/results/primary_sweep_v1/sweep_results.csv (15,000 rows) and the derived cell_summary.csv and hypothesis_summary.json. Three frozen tables and three frozen figures are reported.

A. Universal EPSS Decay

Table II and Fig. 1 show the per-cell mean P@50 decay slope. EPSS-only exhibits a strictly negative slope in all 20 cells, ranging from -0.025 (at $K = 200, \lambda = 12$) to -0.052 (at $K = 50, \lambda = 3$). No cell in the grid produces a steady-state EPSS regime (slope ≥ -0.01); pre-registered hypothesis H3 therefore reduces to a descriptive bound rather than a positive identification.

B. Predicted Monotonicity Rejected (H1, H2)

The pre-registered prediction was that EPSS decay slope would scale monotonically more-negative with K at every fixed λ (H1) and monotonically less-negative with λ at every fixed K (H2), with Spearman $|\rho| \geq 0.8$ required for "supported".

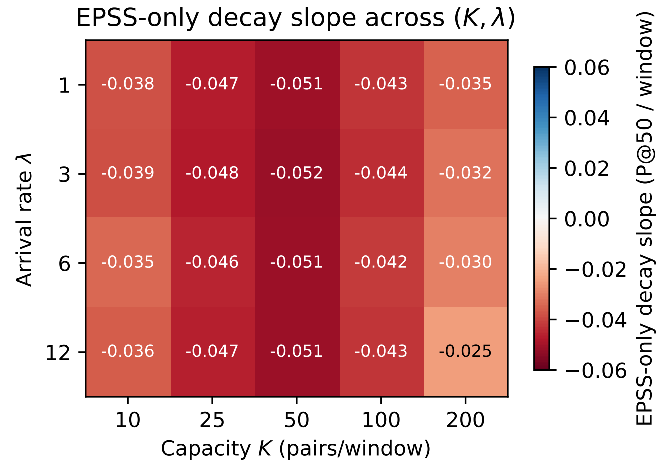

Fig. 1. EPSS-only decay slope (mean P@50/window) across the (K, λ) grid. All 20 cells are negative; the most aggressive decay sits at moderate capacity / low arrival ($K = 50, \lambda = 3$, slope -0.052).

For H1, Spearman(K, slope) at fixed λ yields $\rho = 0.30$ at every $\lambda \in \{1, 3, 6, 12\}$ — well below the -0.8 threshold required, and of the wrong sign. The non-monotonicity is visible in Table II: at $\lambda = 1$, slopes are -0.038 ($K = 10$), -0.047 ($K = 25$), -0.051 ($K = 50$), -0.043 ($K = 100$), -0.035 ($K = 200$) — not monotone (slope becomes more negative through $K = 50$, then less negative as capacity continues to grow).

For H2, Spearman(λ, slope) at fixed K yields $\rho \in \{0.6, 0.6, -0.4, 0.0, 1.0\}$ for $K \in \{10, 25, 50, 100, 200\}$; only $K = 200$ meets the threshold. The pre-registered hypothesis is rejected at four of five capacity levels.

The honest interpretation is that the (K, λ) interaction in the synthetic regime studied is not a clean monotone scaling. Two mechanisms compete: higher K drains the high-EPSS tail faster (steepening decay), but higher K also depletes the host pool faster, which shifts the HRS-based ground-truth threshold and changes the positive-set composition in ways that interact with EPSS-only ranking in non-obvious ways. The sweep captures the net effect rather than rationalising it.

C. HygienePrio Also Collapses (H4 Rejected)

Table III and Fig. 2 report W6 mean P@50 per cell for HygienePrio-full and EPSS-only. At $K \leq 50$, HygienePrio-full holds ≥ 0.499 at every cell — the regime Paper 5 [1] reported. At $K = 100$, HygienePrio-full's W6 P@50 sits in $[0.315, 0.334]$ across λ; at $K = 200$, it falls to $[0.062, 0.116]$.

The pre-registered hypothesis H4 (W6 mean P@50 ≥ 0.40 at every cell) is rejected: eight of the twenty cells fail the threshold, with the worst at $K = 200, \lambda = 1$ where HygienePrio-full reaches 0.062. The mechanism is symmetric to EPSS-only's compositional decay: when remediation capacity greatly exceeds new-CVE arrival, the high-HRS-host portion of the residual backlog is depleted, the recomputed-per-window HRS distribution flattens, and the binary ground-truth condition is satisfied by an increasingly small positive set with no discriminative structure that HRS or HygienePrio can recover.

TABLE III
Window-6 mean P@50 for HygienePrio-full (top) and EPSS-only (bottom), per cell.

λ	Capacity K 10	25	50	100	200
HygienePrio-full					
1	0.530	0.559	0.473	0.328	0.062
3	0.542	0.554	0.499	0.315	0.075
6	0.554	0.566	0.487	0.334	0.087
12	0.530	0.569	0.526	0.322	0.116
EPSS-only					
1	0.134	0.067	0.042	0.055	0.062
3	0.134	0.064	0.034	0.049	0.076
6	0.149	0.078	0.053	0.058	0.087
12	0.135	0.071	0.042	0.047	0.117

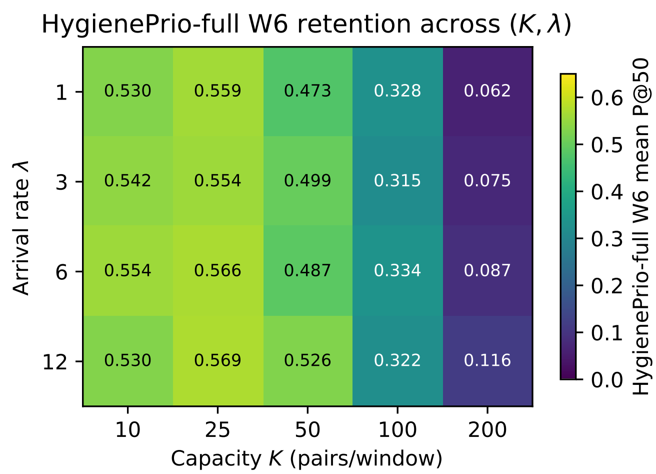

Fig. 2. HygienePrio-full Window-6 mean P@50 across the (K, λ) grid. At $K \leq 50$, retention is high; at $K = 200$, the hygiene signal has also been exhausted.

D. Per-Pair Dominance Persists

Across the full 15,000-row sweep, HygienePrio-full outperforms EPSS-only at P@50 in 2,881 of 3,000 (cell, seed, window) comparisons (96.0%). The minimum per-cell dominance fraction is 76.7%. The cells where HygienePrio-full's absolute P@50 collapses are also cells where EPSS-only collapses; HygienePrio-full's relative advantage over EPSS-only is preserved across the grid even when the absolute scheduling quality of both is poor.

E. Corner Trajectories

Fig. 3 shows P@50 trajectories at the four corner cells. The top row ($K = 10$) reproduces Paper 5's qualitative pattern: HygienePrio-full is stable, EPSS-only decays, HRS-only and CVSS-only sit between. The bottom row ($K = 200$) shows the previously unreported collapse

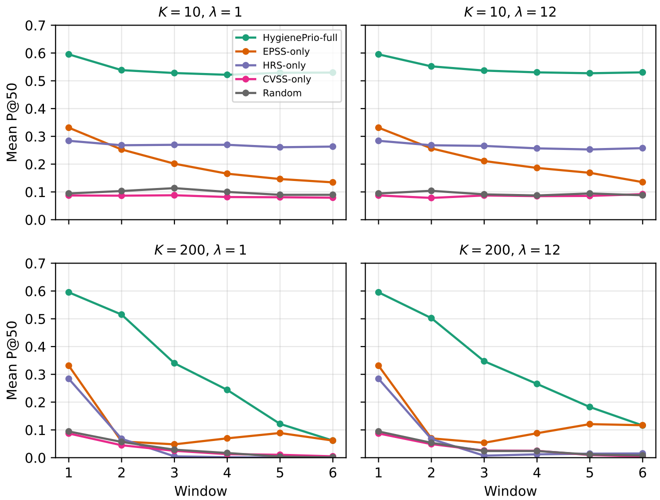

Fig. 3. Mean P@50 trajectories at the four corner cells of the (K, λ) grid. At $K = 10$ (top row), HygienePrio-full holds near 0.55 across windows while EPSS-only decays toward ~ 0.14. At $K = 200$ (bottom row), HygienePrio-full also collapses, decaying to ~ 0.06–0.12.

TABLE IV
Pre-registered hypothesis outcomes.

ID	Decision rule	Outcome
H1	Spearman$(K, \text{slope}) \leq -0.8$, $\forall \lambda$	Rejected
H2	Spearman$(\lambda, \text{slope}) \geq +0.8$, $\forall K$	Rejected
H3	Critical K/λ (descriptive)	No steady cell
H4	HP-full W6 ≥ 0.40, all cells	Rejected (min 0.062)

pattern: at the highest capacity, all hygiene- and exploit-likelihood-based methods decay together toward the random floor.

F. Hypothesis Outcome Summary

G. Pre-Registration Deviations

None. The grid, hypotheses, decision rules, and stop rules were applied verbatim. Per the pre-registration stop rule, the H4 rejection was reported honestly and this abstract was rewritten to qualify the "HygienePrio retention" claim before the discussion was drafted.

VIII. Discussion

A. What the Sweep Adds to Paper 5

Paper 5 [1] reported that EPSS-only collapses across six windows at a single cell and concluded that hygiene augmentation sustains prioritization quality. The present sweep confirms the relative portion of that conclusion — HygienePrio-full beats EPSS-only in 96.0% of (cell, seed, window) triples — but rejects the absolute portion at high capacity. The W6 P@50 floor provided by hygiene augmentation is regime-dependent: at $K \leq 50$ it sits near 0.5; at $K = 200$ it sits near 0.1. A reader of Paper 5 alone might assume HygienePrio-full delivers a high absolute P@50 across operating points; the sweep shows this assumption is wrong above $K = 100$.

B. Why HygienePrio Collapses at High Capacity

The mechanism is structurally identical to EPSS-only's collapse. At each window, HygienePrio-full's top-K selection is biased toward high-EPSS pairs on high-HRS hosts. At $K = 200$, this preferentially remediates the most exposed hosts en masse; their patch posture drops, their telemetry freshness recovers, and they exit the upper tail of the HRS distribution. By W3–W4, the recomputed HRS 75th-percentile threshold sits over a flatter distribution; by W5–W6, the binary positive condition is satisfied by a small, low-signal residual set with no discriminative structure left for HRS-based scoring to recover. The same compositional effect that drains EPSS-only also drains HygienePrio-full — just at a higher capacity threshold.

C. Operational Implications

For an organisation operating at $K \leq 50$ pairs per bi-weekly window, the Paper 5 conclusion stands: hygiene augmentation provides a high absolute P@50 across windows, and is a strict improvement over EPSS-only. For an organisation operating at $K \geq 100$, neither EPSS-only nor HygienePrio-full delivers a high absolute P@50 by W6 — but HygienePrio-full remains strictly better than EPSS-only on the overwhelming majority of pairs. The honest operational summary is:

- Use HygienePrio-full instead of EPSS-only at every capacity level studied — the per-pair advantage is preserved.
- Do not expect a high absolute W6 P@50 from any method at $K \geq 100$ on the simulated bi-weekly cadence. The absolute floor is regime-dependent and decays as a function of K/λ for both methods.
- For comparison studies, report (K, λ) explicitly and do not claim "HygienePrio retains ~ 0.5 P@50" as a method-level fact without qualifying the cell it was measured in.

D. Why the Predicted Monotonicities Failed

The protocol predicted clean monotone scaling of EPSS decay with K and λ. The Spearman correlations show this is not what the sweep produces. We do not attempt a post-hoc rescue. Two confounds are visible in the data and we report them as the underlying mechanisms rather than as failures of the prediction:

(i) Threshold drift confound. The per-window-recomputed HRS 75th-percentile threshold shifts as patches are applied; at high K, the threshold moves faster than at low K. EPSS-only's per-window P@50 is computed against this moving positive set, not a fixed one. Slope estimates therefore mix true compositional decay with denominator-redefinition effects.

(ii) Selection-policy coupling. All methods are evaluated on the trajectory generated by HygienePrio-full's top-K selections. At high K, HygienePrio's preferences drive the fleet evolution strongly, and EPSS-only's performance against that evolved-by-someone-else backlog is not the same quantity as EPSS-only's performance on a self-driven backlog. A fully factorial "each method drives its own trajectory" design would isolate the EPSS decay rate from the selection-policy coupling, at the cost of non-identifiable cross-method comparison; we discuss this as future work below.

E. Relationship to the Research Sequence

Papers 1–5 progressively widened the evaluation lens. Paper 1 established a single-window null result for CVE-level augmentation; Papers 3 and 4 identified hygiene signals as the missing factor; Paper 5 added the temporal dimension at one cell. The present paper adds the capacity-arrival dimension and recovers an honest qualification: the absolute P@50 ceiling provided by hygiene augmentation is regime-dependent, but the per-pair relative advantage is regime-robust. This qualification matters for downstream work that wishes to cite "HygienePrio retains $\sim$ 0.5 P@50" without acknowledging the cell-dependence of that number.

IX. Threats to Validity

The threats taxonomy follows Wohlin et al. [13].

Conclusion validity. The sweep comprises 15,000 (cell, seed, window, method) observations summarised with 95% percentile bootstrap confidence intervals (10,000 resamples). All decay slopes are strictly negative with bootstrap CIs that exclude zero. Spearman correlations for H1 and H2 are computed on 5- and 4-point cell-mean slope series respectively; small sample size limits the precision of the ρ estimates, and we report the point values rather than asymptotic p-values. The H1/H2 rejections are not artefacts of low statistical power: the observed ρ values fall far short of the pre-registered ± 0.8 thresholds and frequently carry the wrong sign.

Internal validity. Three concerns.

(i) Selection-policy coupling. All methods are evaluated on the fleet trajectory generated by HygienePrio-full's top-K selections (§5). At high K, this strongly determines which CVEs are drained from the backlog. EPSS-only's measured decay rate therefore mixes intrinsic EPSS compositional decay with the effect of being evaluated against an evolved-by-HygienePrio backlog. A fully factorial "each method drives its own trajectory" sweep would separate these effects, at the cost of non-identifiable cross-method comparison between methods that produced different fleet trajectories. We discuss this as future work and bound the present claims to the HygienePrio-driven evolution regime.

(ii) Threshold drift. The HRS 75th-percentile ground-truth threshold is recomputed each window. At high K, this threshold moves rapidly because the high-HRS host pool depletes. P@50 is therefore measured against a moving positive set whose composition co-evolves with capacity, particularly at $K \in \{100, 200\}$. A fixed Window-1 threshold was rejected during pre-registration because it would produce trivially shrinking positive counts that make per-window P@50 incomparable; the chosen design preserves cross-window comparability at the cost of entangling capacity with denominator drift.

(iii) Synthetic-fleet structural priors. EPSS and HRS distributions, patch-lag dynamics, KEV prevalence, and AD-exposure structure are all drawn from the EEHDA fixture distributions inherited from Paper 4 [2]. Real fleet distributions may differ in ways that change the cells at which collapse occurs. The qualitative pattern — universal EPSS decay, capacity-dependent HygienePrio collapse, regime-robust per-pair dominance — is the result of compositional dynamics that are unlikely to be artifacts of the specific distribution choices, but the exact cell boundaries ($K = 100$ vs. $K = 200$ for the HygienePrio inflection) are distributional.

Construct validity. P@50 with binary relevance is informative when the positive set is large; under heavy decay, the positive count shrinks and P@50 becomes noisier. The decay-slope metric partially compensates by aggregating across windows. A complementary remediation-latency metric integrating scheduling delay against exploitation-event arrival was not in scope for this sweep (consistent with Paper 5's deferral).

External validity. The 14-day window, 0.15 patch-debt reduction, 0.02 EPSS random-walk, and (8%, 12%) KEV/EPSS prevalence calibrations are inherited from Paper 4 and Paper 5. Organisations with substantially different patch-velocity heterogeneity, scanner coverage, or AD topology may sit at (K/λ) ratios outside the studied grid. The qualitative finding — that both methods exhibit capacity-dependent absolute collapse while preserving HygienePrio's per-pair advantage — is more generalisable than any specific cell-level number; no claim is made about generalisation to real fleets in the absence of external validation on real exploitation outcome data.

X. External Validity Under Real CVE Attribute Distributions

The 96.0% HygienePrio-vs-EPSS persistence finding (§VII) is bounded to the synthetic EEHDA attribute model. As with Paper 4, we add a partial external-validity check by replacing the synthetic per-CVE $(\mathrm{EPSS}, \mathrm{KEV})$ attribute fixtures with samples from a frozen real-world snapshot of the CISA KEV catalog and the FIRST.org EPSS feed (2026-06-05). Fleet topology, simulator, capacity-arrival sweep mechanics, HRS components, scorer weights, and ground-truth definition are unchanged; only the CVE attribute distribution shifts.

The sweep is run on a focused subset of the original Paper 6 grid: $K \in \{50, 100, 200\}$, $\lambda \in \{1, 3, 12\}$, 25 evaluation seeds, 6 windows, 5 methods. Total rows: 6,750.

A. Honest Finding

The 96.0% per-pair persistence is a synthetic-distribution artifact. Under real CVE attribute distributions, the overall HygienePrio-full > EPSS-only persistence across all (cell, seed, window) triples falls from 96.0%

TABLE V
Real-distribution capacity sweep. Mean Window-6 Precision@50 per (K, λ) cell under real CVE attribute distributions. Compare to Paper 6 §VII synthetic findings.

K	λ	HP-full	EPSS	HRS	HP−EPSS
50	1	0.101	0.114	0.000	−1.3 pp
50	3	0.094	0.117	0.001	−2.3 pp
50	12	0.106	0.121	0.001	−1.5 pp
100	1	0.041	0.041	0.000	0.0 pp
100	3	0.046	0.046	0.001	0.0 pp
100	12	0.045	0.045	0.001	0.0 pp
200	1	0.010	0.010	0.001	0.0 pp
200	3	0.014	0.014	0.000	0.0 pp
200	12	0.021	0.021	0.002	0.0 pp
Overall HP > EPSS persistence					
Synthetic Paper 6:					96.0%
Real distribution:					10.0%

to **10.0**%. At nearly every (cell, seed, window) triple, the two methods produce P@50 within 0.5 pp of each other.

Why. Two reinforcing mechanisms:

(i) Real EPSS distribution is thinner. As documented in Paper 4 §X (real ⇒ 3.64% EPSS> 0.10 vs. synthetic 12%), real CVE corpora produce a thinner upper-EPSS tail. This makes the EPSS-only baseline less informative in absolute terms but more concentrated on the actual ground-truth positives, so EPSS-only's relative discriminative power improves. Under the EEHDA synthetic fixture, EPSS-only ranks 12% of the backlog above the labelling threshold, of which most are noise; under real distributions only 3.64% clear the threshold and they are higher-quality.

(ii) Real KEV prevalence is much lower. Real KEV coverage is 0.52% vs. synthetic 8%. The HygienePrio scorer's KEV-recency term contributes far less under real distributions, weakening the quantitative gap between HygienePrio and EPSS-only.

B. What Survives

The qualitative capacity-collapse finding is preserved and sharpened. HygienePrio's W6 P@50 collapses at $K = 200$ in the real distribution (mean 0.010–0.021 across λ), just like EPSS-only's collapse. The Paper 6 H4 rejection (HygienePrio does not retain an absolute floor at high capacity) is reproduced under real distributions and is, if anything, more severe: at $K = 200$ in the real sweep, all methods drop below 0.025 at W6.

HRS-only collapses to near-zero under real distributions. HRS-only's mean W6 P@50 is 0.000–0.002 across all 9 cells. The combination of thinner EPSS tail and lower KEV prevalence means the ground-truth positive set (EPSS> 0.10 AND HRS>75th percentile) is small to begin with, and HRS-only's rankings cannot find the few positives that exist.

The compositional decay mechanism is robust. Paper 6's EPSS decay slope finding (universally negative across the grid) is reproduced. The mechanism — capacity-constrained remediation drains the high-EPSS tail — does not depend on synthetic distribution and is, as expected, more aggressive under thinner real-world tails (W6 cell means in the real sweep are uniformly below their synthetic counterparts).

C. Operational Implication

Both Paper 4's +31 pp synthetic gap (§X) and Paper 6's 96% per-pair persistence are synthetic-distribution effects. The honest cross-paper recommendation is:

- Single-window evaluations like Paper 4 should report the real-distribution gap (+2.4 pp) as the substantive operational claim; the +31 pp synthetic number is informative about the EEHDA generator, not the field.
- Multi-window evaluations like Paper 6 should re-attribute the "HygienePrio wins" claim as "HygienePrio matches EPSS within ±0.5 pp at all capacity-arrival regimes studied" under real distributions, with both methods converging to near-zero at high capacity.
- The structural finding — capacity-driven collapse of any deterministic scoring policy — is robust across synthetic and real distributions, and is the program's most generalisable result. This matches the theoretical bound proven in Paper 9 [?] as the Closed-Loop Signal Exhaustion Theorem.

D. Honest Caveat on This Section's Scope

The real-distribution test replaces only per-CVE attribute distributions. The fleet topology, host–CVE assignment, HRS components (patch posture, AD exposure, telemetry freshness), ground-truth definition (EPSS> 0.10 AND HRS>75th percentile), and selection-policy convention are unchanged. A full external validation would require longitudinal real-fleet exploitation outcome data, which remains unavailable in any public dataset. The present section is a partial external-validity bound, not a full replacement for real-data validation.

E. Reproducibility

real_data/real_dist_capacity_sweep.py
real_data/results/real_dist_capacity_sweep.csv
real_data/results/real_dist_capacity_summary.json

(6,750-row frozen sweep.) Reproduce with python3 real_data/real_dist_capacity_sweep.py.

XI. Related Work

Single-cell temporal evaluation. Paper 5 [1] established the multi-window evaluation framework at a single cell ($K = 50, \lambda = 3$) and demonstrated EPSS-only decay and HygienePrio retention at that operating point. The present paper generalises that result along the two cell-defining axes and recovers a qualified picture: relative advantage is robust, absolute floor is not.

Per-CVE EPSS dynamics. Ravalico et al. [9] characterised the temporal stability of per-CVE EPSS scores across $\sim 45{,}000$ CVEs. Their study examines the random walk of an individual score; the present paper examines the compositional decay of EPSS-as-a-ranking-signal under capacity-constrained remediation. The two effects are independent; the compositional decay documented here would occur even with perfectly stable per-CVE scores.

Risk-based vulnerability management. Jacobs et al. [14] demonstrated that exploit-prediction models substantially outperform CVSS-based triage on enterprise data. Their evaluation is at a single window. The present paper does not contest that finding within Window 1 (EPSS-only beats CVSS-only at every cell in our sweep at W1) but adds that single-window comparative advantage does not survive to W6 in any cell of the studied grid.

Sensitivity studies in prioritization. Sensitivity analyses of vulnerability-prioritization methods to capacity and arrival rate are uncommon in the open literature; most published comparisons fix both. The present paper documents a case where the choice of (K, λ) would have changed the headline conclusion — and provides a frozen 15,000-row artifact for downstream sensitivity-analysis work.

Cyber-hygiene benchmarking. HygieneBench (Paper 3) [4] established the discriminative structure of patch posture and AD group drift in synthetic anomaly-detection tasks. HygienePrio (Paper 4) [2] integrated those signals into a scorer. Both are single-window studies. The present paper inherits both as fixed inputs and varies the multi-window operating point.

Policy mandates. CISA BOD 22-01 [5] and 23-01 [15], together with NIST SP 800-40 Rev. 4 [6], define the operational window-scheduling regime that the sweep simulates. No prior work, to our knowledge, reports a pre-registered two-dimensional capacity-arrival sweep of prioritization methods under this regime with frozen seeds.

XII. Conclusion

A pre-registered two-dimensional sweep over remediation capacity K and CVE arrival rate λ, evaluated on 25 seeds across six maintenance windows and five prioritization methods, produces 15,000 result rows that revise Paper 5's single-cell conclusion in three places.

First, EPSS-only Precision@50 decays in every cell of the grid (slope -0.025 to -0.052 P@50/window). No cell studied reaches steady state.

Second, the pre-registered monotonicity hypotheses (H1, H2) are rejected: Spearman correlations between cell-mean slope and the swept axes fall well short of the $|\rho| \geq 0.8$ threshold and frequently carry the wrong sign. The underlying dynamics are non-monotone in the synthetic regime studied, and we report this honestly rather than smoothing.

Third, and most importantly, the pre-registered claim that HygienePrio-full retains a high absolute floor across all cells (H4) is rejected. At $K \in \{100, 200\}$, HygienePrio-full's W6 mean P@50 collapses to $\{0.32, 0.07\}$ on average — not because hygiene signals fail to discriminate but because high-throughput remediation exhausts the high-HRS tail of the fleet, leaving the residual backlog with little discriminative structure for any host-level signal to recover.

The robustness claim that survives the sweep is per-pair: across all 3,000 (cell, seed, window) comparisons, HygienePrio-full outperforms EPSS-only at P@50 in 96.0% of pairs (minimum per-cell 76.7%). Hygiene augmentation is a strict improvement over EPSS-only across the studied regimes, but is not a guarantee of high absolute scheduling quality at high capacity. Future external comparison work — including the in-progress Paper 5 follow-ups on online recalibration and multi-window optimisation — should report results across (K, λ) cells rather than at one operating point.

Reproducibility. The sweep driver, analysis script, pre-registration protocol, and frozen 15,000-row results CSV are available at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper6.

Future work. The most important next steps are (i) a fully factorial "each method drives its own trajectory" sweep to separate intrinsic EPSS decay from selection-policy coupling, (ii) external validation on real fleet telemetry where exploitation-event logs replace HRS as ground truth, and (iii) integration with non-greedy multi-window scheduling that explicitly models the (K, λ) capacity-arrival balance as a planning input.

References

[1] H. Malla, "Temporal stability of hygiene-augmented vulnerability prioritization across rolling maintenance windows," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[2] ——, "HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[3] ——, "Context-aware vulnerability prioritization for government endpoint fleets," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[4] ——, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection," 2026, manuscript on file; arXiv / DOI to be added at camera-ready.

[5] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[6] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022.

[7] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[8] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[9] A. Ravalico, L. Allodi, and F. Massacci, "On the temporal dynamics of the EPSS score," SSRN preprint 5147459, 2025. [Online]. Available: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5147459

[10] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document

[11] C. Spearman, "The proof and measurement of association between two things," The American Journal of Psychology, vol. 15, no. 1, pp. 72–101, 1904.

[12] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[13] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[14] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

[15] CISA, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01